

Business Continuity Policy

Policy ID: HH-ISMS-08 **Version:** 1.0 **Effective Date:** 2026-08-29 **Owner:** Venkat Narasimha (Processbricks) **Review Cycle:** Annual **Last Reviewed:** 2026-08-29

Classification: Internal

1. Purpose

A hospital that loses its shift-management system cannot pay staff, cannot schedule shifts, and cannot prove compliance with labor law. Business continuity is the discipline that decides — before disaster strikes — what we will recover, in what order, within what time, and from what source.

This policy defines:

- **Business Impact Analysis (BIA)** — what's critical at Haritha and what's not.
- **RTO / RPO targets** — how fast and how fresh we recover.
- **DR strategy** — backup-based restore, offsite copy, cold storage.
- **Backup architecture** — local + offsite + (future) cold.
- **Testing cadence** — quarterly DR drill, annual tabletop.
- **Communication plan** — who to notify, when, how.
- **Vendor dependencies** — what if DuckDNS, GitHub, or the offsite VPS fail.
- **Insurance / legal** — placeholder for future HIPAA/DPDP considerations.

The 2026-08-10..18 backup silent-failure streak (LEARNINGS #79, #80, #113, #114) is the cautionary tale: if we hadn't discovered the gap during a routine restore drill on 2026-08-18, the next real disaster would have found us with 8-day-stale backups — far outside the 6-hour RPO target.

2. Scope

2.1 In scope

- **BIA** for Haritha Hospitals — Roster, Attendance, Payroll, Employee records.
- **RTO / RPO** targets per system tier.
- **DR strategy** — backup-based restore, offsite, cold.
- **Backup architecture** — local + offsite + git (code).
- **DR drill cadence** — quarterly full restore + annual tabletop.
- **Communication plan** during DR.
- **Vendor failure scenarios** — DuckDNS, GitHub, offsite VPS, Let's Encrypt.
- **Insurance / legal** — placeholder.

2.2 Out of scope

- **Incident response procedure itself** — see 07-incident-management (sibling).
- **Day-to-day backup cron operation** — see 05-operations-security §3.1.
- **TLS / SSH key management** — see 04-cryptography.
- **Network architecture** — see 06-communications-security.
- **Restore procedure step-by-step** — see ../04-runbooks/04.3-disaster-recovery.md.

3. Policy Statement

3.1 Business Impact Analysis (BIA)

System / data	Critical for?	Tier	Max tolerable downtime
pberpprod Roster	Daily shift assignment; nurses can't work without it	Tier 1 (Critical)	1 hour
pberpprod Attendance	Payroll input; salary slips delayed	Tier 1 (Critical)	4 hours (by next payroll)
pberpprod Employee records	Onboarding, offboarding, ID generation	Tier 2 (Important)	24 hours
pberpprod Payroll	Monthly salary computation	Tier 1 (Critical) during payroll week; Tier 2 otherwise	4 hours during payroll week
pberpprod Shift Type	Drives auto-attendance cron	Tier 2 (Important)	24 hours
pberpprod Audit logs (tabVersion)	Forensics + compliance	Tier 3 (Compliance)	7 days
pberpqa	Mirror of prod for testing	Tier 4 (Dev/QA)	best-effort
pberpdev	Scratch space for development	Tier 4 (Dev/QA)	best-effort
dev-erp (venkat VPS)	Venkat's prototyping env	Tier 4 (Dev/QA)	best-effort
Git remote (venkata-narasimha/haritha_hospitalizations)	Code + configurations + docs	Tier 1 (Critical)	1 hour to restore from local clone + git history
Backup tarballs (local + offsite)	Recovery primitive	Tier 0 (Foundational)	0 (must always exist + be valid)

Decision rule: if Roster is down, nurses can't work. The cost of unavailability is "shifts missed, payroll delayed, clinical risk". Tier 1.

3.2 RTO / RPO targets

Scenario	RTO (Recovery Time Objective)	RPO (Recovery Point Objective)	Rationale
Single container crash, named volumes intact	15 min	0 (named volumes preserved)	docker restart only; no restore needed
Single container data wipe	30 min	6 hours	restore from latest backup slot
Host down (VPS provider failure)	1 hour	6 hours	provision new VPS + restore
Region-wide outage (both VPSes down)	4 hours	6 hours	rebuild from cold storage + GitHub
Total loss (data + code + VPSes + offsite)	8 hours	6 hours (last good backup)	rebuild from cold storage only

Why 6-hour RPO: backup cron runs every 6 hours (0 */6 * * * IST — 00:00 / 06:00 / 12:00)

/ 18:00). Worst case data loss = 6 hours of attendance/leave/payroll records entered after the last successful backup slot.

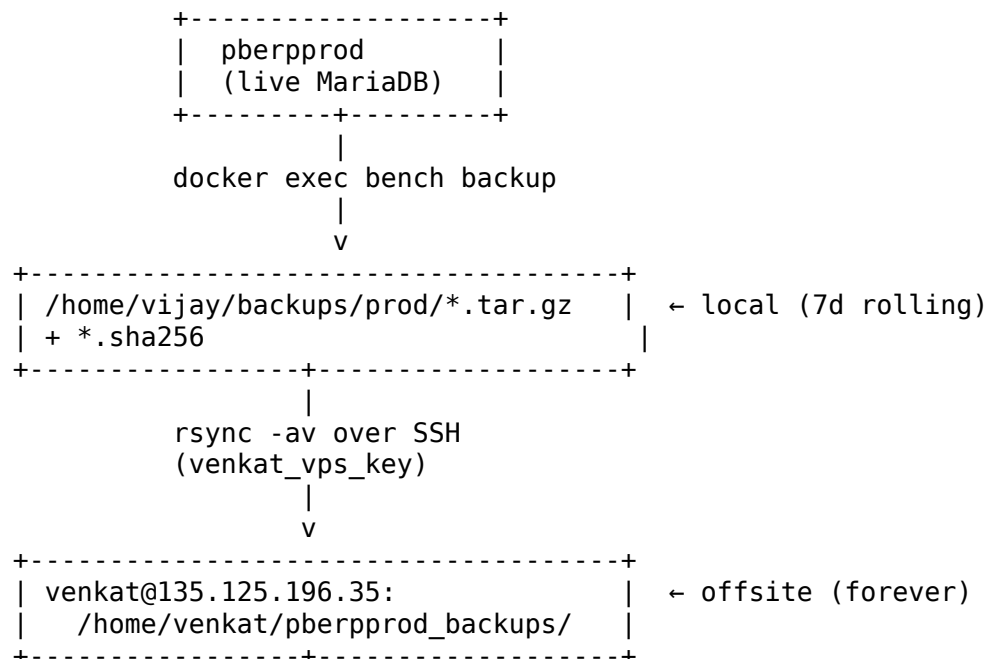
Why 1-hour RTO (host down): offsite backup is hot (rsync'd immediately after creation), new VPS can be provisioned in 5-10 min on DigitalOcean / Linode / Hetzner, restore + bring-up = ~30 min.

Why 8-hour RTO (total loss): cold storage retrieval adds 1-2 hours. New VPS provisioning 5-10 min. Restore ~30 min. Code clone from GitHub ~5 min. App install + fixtures + smoke ~15 min. Total ~3 hours; padded to 8 for unforeseen issues.

3.3 DR strategy

1. **Backup-based restore is the primary strategy.** We do NOT maintain a hot standby or active-passive cluster. A new VPS + restore from offsite is the recovery path. Rationale: cost (no second VM running 24/7), complexity (no replication to maintain), and acceptance that 1-hour RTO for "host down" is sufficient for a hospital system that's not safety-critical in real time.
2. **3-2-1 baseline.** Three copies, two media, one offsite. Per 01-info-security §3.4 and 05-operations-security §3.1.
3. **Local = 7-day rolling.** /home/vijay/backups/{prod,qa,dev}/ retains 7 days of tarballs.
4. **Offsite = forever.** venkat@135.125.196.35:/home/venkat/{pberpprod,pberppqa,pberppdev}_backup retains forever.
5. **Code = git remote.** git@github.com:venkat-narasimha/haritha_hospitals.git (custom app + docs) and git@github.com:venkat-narasimha/erpclaw.git (compose files + scripts).
6. **Cold storage = future** (§9). Backblaze B2 weekly export, encrypted with age. Not implemented today.
7. **No encrypted backups at rest** (per 04-cryptography §3.6 future). Acceptable for v1 (private offsite VPS + single-operator trust). Scheduled for v2.

3.4 Backup architecture



1. STOP all changes (notify Venkat: "DR in progress, no deploys until cleared")
2. Post status to memory/YYYY-MM-DD.md every 30 min:
 - what step you're on
 - what's verified
 - what's still uncertain
3. If RTO at risk (60 min approaching for "host down"): notify Venkat IMMEDIATELY
4. If data loss discovered: notify Venkat IMMEDIATELY (don't continue silently)

After DR (post-mortem) Within 24 hours: - Update LEARNINGS.md with new lessons - Update ../04-runbooks/04.3-disaster-recovery.md with any gaps found - Notify Venkat: "DR complete. {time-to-recover}. {data-loss-if-any}." - If RTO breached: schedule retro to identify root cause

External (if user-facing) Use the user-facing template from 07-incident-management §3.5. For DR events > 4 hours, also notify the hospital's IT lead (Venkat routes this via the existing Telegram channel).

3.7 Vendor dependencies

Vendor	What we depend on	Failure scenario	Mitigation
DuckDNS	Dynamic DNS for *.duckdns.org	DuckDNS down or token revoked	Manual IP update via API (per 06-communications-security §6a Edge 8); 5-min cron interval catches transient outages
Let's Encrypt	TLS cert for *.duckdns.org	ACME challenge blocked	Force-renew with certbot renew --force-renewal; switch to DNS-01 challenge if HTTP-01 blocked (per 04-cryptography §6a Edge 2)
GitHub	Code + customizations + docs repo	GitHub down (rare) or repo deleted (catastrophic)	Local clone of the repo on both VPSes + the local container; we can push from local to a new remote (Bitbucket, GitLab, self-hosted Gitea) within hours
Offsite VPS (135.125.196.35)	Receives daily rsync	Offsite VPS down	Per 01-info-security §6a Edge 5 + 05-operations-security §6a Edge 3: SEV-3 at 4h, SEV-2 at 24h. Add second offsite (B2 / Wasabi) tracked in §9

Vendor	What we depend on	Failure scenario	Mitigation
VPS provider (main VPS)	Hosts all envs + compose + Docker	Provider failure (outage, account suspension, hardware failure)	New VPS provisioning 5-10 min; restore from offsite ~30 min; total RTO 1h per §3.2
Certbot (Let's Encrypt client)	TLS renewal automation	Certbot broken	Manual cert renewal; or pin a static cert (degraded)
VPS time / NTP	Cron timing	Time drift / NTP down	Daily heartbeat probes slot ran within ± 15 min (LEARNINGS 2026-05-28 batch); manual cron restart if needed
Processbricks admin (Venkat)	Single operator	Venkat unavailable > 24h	Per 02-access-control §6a Edge 6; defer non-critical, document the unavailability

3.8 Insurance / legal

Status: placeholder (TBD).

A future revision of this policy will cover:

- **Cyber insurance.** A policy that covers breach response, business interruption, and forensic costs. Not currently in place. Tracked in §9.
- **DPDP Act 2023 compliance.** Data Protection Officer (DPO) appointment if Haritha crosses the “significant data fiduciary” threshold. Currently below threshold (single hospital, < employee count cutoff). Tracked.
- **HIPAA-equivalent (India).** India does not have a single HIPAA equivalent; the IT Act 2000 + DPDP Act 2023 cover most of the same ground. Legal review is TBD.
- **Hospital's IT vendor contract.** Processbricks is the IT vendor; the MSA / SLA terms are documented separately. Tracked.

3a. Current State (as of 2026-08-29)

What we have TODAY

Continuity layer	Component	Where it lives	Status
Backup	Local (vijay VPS)	/home/vijay/backups/{prod,qa,dev}/	Live
Backup	Offsite (venkat VPS)	/home/venkat/{pberpprod, pberppdev}_backups/	Live
Backup	dev-erp (reversed direction)	/home/venkat/backups/dev-erp/ + /home/vijay/backups/deverp/	Live
Backup	SHA-256 sidecar	*.tar.gz.sha256	Live
Backup	Sentinel line	BACKUP_OK sha=... in cron log	Live (post-LEARNINGS #113 fix)

Continuity layer	Component	Where it lives	Status
Backup	Encryption at rest	NOT implemented	Gap (per 04-cryptography §3.6)
Cold storage	Backblaze B2 / S3 Glacier	NOT implemented	Gap (§9)
DR drill	Monthly subset	../04-runbooks/04.2-daily-ops.md §“Monthly checks” per LEARNINGS #48 + ../04-runbooks/04.3	Live
DR drill	Quarterly full	per §3.5.3	Pending first run (Q4 2026)
DR drill	Annual tabletop	07-incident-management §3.5	Pending
Communication	Internal templates	per §3.7	Live
Communication	User-facing templates	07-incident-management §3.5	Live
Vendor deps	DuckDNS, Let’s Encrypt, GitHub, offsite VPS, certbot, NTP, Venkat	per §3.7	Live; mitigations documented
Insurance / legal	cyber insurance, DPDP DPO, MSA	NOT in place	Placeholder

What is WORKING

- **Backup cron is now reliable for prod** (post-2026-08-19 fix). Slot #1 + #2 of 2026-08-19 both PASSED with BACKUP_OK sha=... sentinel. 8-day silent-failure streak (2026-08-10 to 2026-08-18) reset. Per LEARNINGS #79, #80, #113.
- **Offsite rsync is hot.** Within minutes of a local backup completing, the offsite copy is up to date. SHA256 cross-check confirms integrity.
- **Restore procedure is documented and testable.** ../04-runbooks/04.3-disaster-recovery.md §“Full prod rebuild procedure” has 12 steps; the manual restore drill on 2026-08-18 (the one that discovered the silent-failure streak) followed a similar pattern.
- **3-2-1 baseline holds** for prod (local + offsite + git remote for code). Single-operator trust model.
- **Vendor failure scenarios are mapped** (§3.7) with documented mitigations.

Known GAPS

1. **No cold storage.** Offsite is one private VPS, not geographically distant. A region-wide event (e.g., a natural disaster affecting both VPSes) would leave us with only the local clone + git remote. Tracked in §9.
2. **No encrypted backups at rest.** Tracked in 04-cryptography §3.6. Offsite is private + single-operator trust; acceptable for v1.
3. **No quarterly full DR drill run yet.** First one scheduled Q4 2026 (target: 2026-11-15). Until then, we have the monthly subset drill + the 2026-08-18 manual discovery.
4. **No annual tabletop run yet.** Pending.
5. **No cyber insurance.** Tracked in §9.
6. **No formal DPDP compliance review.** Below the significant data fiduciary threshold today; would need revisiting if Haritha expands.
7. **No documented hospital IT lead contact for external DR communication.** Venkat is both Processbricks owner and Haritha’s de facto IT lead. If Venkat is unavailable during a > 4h DR, who calls the hospital? Tracked.

8. **Restore procedure assumes venkat VPS is reachable.** If both VPSes are down, the only recovery path is git remote + cold storage (which doesn't exist). The "total loss" scenario RTO of 8h assumes cold storage exists. Today, total loss = effectively unrecoverable beyond what git remembers.

These gaps are explicit v1 scope decisions. Listing them is transparency, not apology.

3b. Concrete Examples (Haritha history)

Real continuity incidents and near-misses that shaped this policy.

Example 1 — 2026-08-10..18 prod backup silent-failure streak (LEARNINGS #79, #80, #113, #114)

- **What happened.** `prod_backup.sh` ran 4x/day from 2026-08-10 through 2026-08-18. Every slot failed silently. No cron error, no `BACKUP_OK` sentinel, empty offsite rsync target. The 8-day RPO violation was undetected.
- **Root cause.** Stale `apps.txt` `hrms` reference + `set -euo pipefail + $(ls *.tar.gz)` command-substitution trap + missing sentinel line. Three stacked issues; all silent.
- **Detection.** 2026-08-18: Venkat discovered during a manual restore drill. **The heartbeat didn't catch it** because the heartbeat either wasn't running or wasn't probing this metric.
- **Response.** Hardened `prod_backup.sh` (timeout 900, `PIPESTATUS`, sentinel line). Verified 2026-08-19 with two consecutive cron slots passing. Lessons #79, #80, #113, #114.
- **Continuity lesson:** "Backup ran without error" is not "backup is succeeding". A positive probe (`sha256sum` matches between local and offsite) is the only assertion that matters. §3.5 codifies monthly restore drill as a baseline, quarterly full drill as a deeper verification. **The 2026-08-10..18 streak is exactly the failure mode quarterly drills exist to prevent — if the drill had been running, it would have caught the gap by 2026-08-11.**

Example 2 — 2026-08-18 cron race condition + the offsite rsync it almost broke (LEARNINGS #77, #78)

- **What happened.** Three concurrent agents edited the crontab via the unsafe `crontab -l | sed | crontab - pattern`. The offsite rsync cron line was among the corrupted ones.
- **Root cause.** Shared system state with no transactional isolation.
- **Response.** Atomic heredoc pattern. Crontab hash: `941eeefc977ae1aabb185e8a5a94c4dcdeed649d45`
- **Continuity lesson:** Offsite rsync is a Tier 0 primitive — backup must always work. The cron that drives it must be atomic; the script must be hardened. Both layers must be verified daily. §3.4 codifies the verification (heartbeat checks offsite rsync freshness per 05-operations-security §3.3.1).

Example 3 — 2026-08-22 SSH key chmod issue + offsite reachability (LEARNINGS #93)

- **What happened.** `/root/.openclaw/*.key` files lost 0600 mode after filesystem drift. SSH to offsite VPS failed with `Permission denied`. Offsite rsync cron failed.
- **Root cause.** Filesystem mode is host-level state that drifts.
- **Response.** Periodic `chmod 0600` in bootstrap script. Cron + script integrity check now part of the weekly heartbeat (LEARNINGS #74).
- **Continuity lesson:** Offsite rsync depends on three things: cron entry, script executable, SSH key mode. All three must be verified. The LEARNINGS #74 6-check audit covers all three. §3.4 codifies the per-component verification.

Example 4 — 2026-08-19 dev-erp scheduler 1045 + the backup that worked anyway (LEARNINGS #87)

- **What happened.** erpdev-scheduler-1 had MySQL 1045 for the site user; scheduled events silently failed. **But the backup cron kept working** — backup uses container env var directly, not scheduler events.
- **Status.** Scheduler issue pending Venkat approval for grant fix. Backup cron unaffected.
- **Continuity lesson:** When designing a recovery primitive, prefer primitives that don't depend on the system being recovered. Backup cron + container env vars = independent of scheduler. This is exactly what §3.4 codifies — the cron + SSH key + script trio is the recovery primitive, not the scheduler.

Example 5 — 2026-08-29 gunicorn --preload outage — recovery that worked (LEARNINGS #153)

- **What happened.** HTTP 500 on every request for ~10 min. Both prod and dev. Data was safe (named volumes preserved, verified per LEARNINGS #72).
- **Root cause.** Gunicorn froze sys.path; new app invisible until container restart.
- **Response.** docker restart erp-{env}-backend-1 in parallel. Zero data loss. Total RTO ~10 min — well inside the 15-min “single container” RTO target.
- **Continuity lesson:** The Tier 1 RTO target (1h) was met with a 10-min recovery. The named volume pattern (per LEARNINGS #154) is what made the recovery safe. §3.2 codifies the 15-min “single container” RTO tier — this incident validates it.

Example 6 — 2026-08-29 prod DB password drift — secondary failure during primary fix (LEARNINGS #154)

- **What happened.** During the gunicorn outage resolution, prod login returned 401. The password literal in MEMORY.md had drifted from the container env. The fix worked (Frappe responsive) but the credential didn't match.
- **Root cause.** Hardcoded credential in long-lived markdown doc; rotation in a previous session updated the env but not the doc.
- **Response.** Canonical read pattern: docker exec erp-prod-db-1 printenv MYSQL_ROOT_PASSWORD. Quarterly verification.
- **Continuity lesson:** Secondary failures during primary fixes are common. The playbook's “form hypothesis, verify before acting” (LEARNINGS #72) caught it before the admin escalated the 401 to a separate SEV-1. §3.6 (post-mortem includes secondary findings) codifies this.

Example 7 — 2026-08-29 prod login 401 → password retrieved from container env (LEARNINGS #154, #157)

- **What happened.** Within minutes of the gunicorn fix, the prod login 401 was diagnosed and resolved by docker exec erp-prod-db-1 printenv MYSQL_ROOT_PASSWORD. No backup restore needed; no second outage.
- **Continuity lesson:** The “source of truth for credentials is container env, not docs” rule is a continuity rule, not just a security rule. If the credential is wrong but the data is intact, recovery is minutes, not hours. §3.4 codifies this as part of the backup architecture — credentials travel with the bundle.

Example 8 — 2026-08-21 disk near-full + the prune that prevents DR failure (LEARNINGS #91)

- **What happened.** Main VPS disk at 95%. 13.4G reclaimable from dangling Docker images.
- **Root cause.** No prune cron; image swap history accumulated.
- **Response.** Weekly Sunday 04:00 IST `docker image prune -a` cron.
- **Continuity lesson:** DR fails not just from missing backups but also from “the new VPS can’t run because disk is full during restore”. Disk space is a continuity concern. §3.5.1 (monthly restore drill) implicitly tests disk; the LEARNINGS #91 prune cron is the upstream preventive.

Example 9 — 2026-05-28 timezone + cron restart interaction (LEARNINGS)

- **What happened.** VPS timezone changed; cron daemon continued using the OLD timezone. Backup slots didn’t fire for ~6h until cron was restarted.
- **Root cause.** cron reads `/etc/localtime` + `/etc/timezone` only at start.
- **Response.** Post-timezone-change checklist: `systemctl restart cron`. Daily heartbeat verifies slot ran within ± 15 min.
- **Continuity lesson:** Time is a security primitive AND a continuity primitive. A backup that “ran” at the wrong time is not a backup. §3.4 + §3.5 codify the time verification.

Example 10 — 2026-08-14 sub-agent verification gap (LEARNINGS #72)

- **What happened.** Sub-agent “done” reports had silent discrepancies (nginx worker count, git pull state). The work was technically complete but functionally wrong.
- **Root cause.** Sub-agent verified “the script parses” but not “the script behaves”.
- **Response.** Parent-verify checklist: worker/process counts via `ps/ss`; git state via `git rev-parse`; file content via `sha256sum/stat`; service health via direct REST call.
- **Continuity lesson:** DR restore is the same class of work — a “restore ran” report is meaningless without a “restored env serves login + sample records” verification. §3.5.2 (quarterly full DR drill) pass criteria explicitly require login + sample-records-queryable.

4. Responsibilities

Role	Responsibilities
Venkat Narasimha (Owner)	Approves this policy + RTO/RPO targets. Owns the offsite VPS + cold-storage decisions. Approves all DR drills. Performs annual tabletop. Files annual cyber-insurance + DPDP review.
Processbricks admin	Runs monthly restore subset drill. Quarterly full DR drill (with Venkat approval for prod env). Reports backup health daily. Maintains backup cron + scripts.
Subagents (automation)	Heartbeat probe offsite freshness + slot ran-within-15-min. Surface backup failure immediately. Never auto-trigger DR without Venkat approval.
All users	Report anomalies within 1h (per 01-info-security §3). Don’t bypass MFA. Don’t manually edit crontab without approval.

Role	Responsibilities
Vendors	Bound by contract to provide 24h breach notification + 7-day CVE notification + data-residency compliance.

5. Compliance Measurement

Check	Frequency	Owner	Source of truth
Local backup freshness (≤ 6 h lag)	Daily	admin	ls -lt /home/vijay/backups/prod/
Offsite backup freshness (≤ 6 h lag)	Daily	admin	SSH to offsite, list dir
Backup BACKUP_OK sentinel present	Daily	admin	cron log last line
Backup SHA-256 cross-check (local vs offsite)	Daily	admin	sha256sum compare
Monthly restore drill (subset, gzip parse + CREATE TABLE count)	Monthly	admin	../04-runbooks/04.2-daily-ops.md \$“Monthly checks”
Quarterly full DR drill	Quarterly	Venkat	../04-runbooks/04.3-disaster-recovery.md \$“Test cadence” tabletop notes
Annual tabletop (total-loss scenario)	Annually	Venkat	
RTO/RPO actual vs target (per incident / per drill)	Per drill + per real DR	Venkat	drill log + post-mortem
Cold storage verification	(when implemented)	admin	Backblaze B2 / S3 Glacier
Vendor dependency status (DuckDNS, Let’s Encrypt, GitHub, offsite VPS)	Daily	admin	heartbeat probes
Insurance / DPDP review	Annually	Venkat	legal review
Backup encryption-at-rest status	(when implemented)	admin	04-cryptography §3.6

KPI dashboard:

KPI	Target	Source
Offsite backup freshness	≤ 6 h lag	rsync target timestamp
Backup slot success rate	100% (no failed slots)	cron log sentinel
RTO actual vs target (Tier 1)	≤ 1 h	post-mortem timeline
RPO actual vs target (Tier 1)	≤ 6 h	last backup slot timestamp
DR drill on schedule	100%	calendar

KPI	Target	Source
Vendor-dependency downtime	0	vendor status pages

6. Exceptions

1. **No cold storage today** (§3a GAPS #1). Acceptable for v1 (single-operator trust + 3-2-1 baseline holds). Tracked in §9.
2. **No encrypted backups at rest** (04-cryptography §3.6). Same trust model.
3. **No cyber insurance** (§3.8). Tracked in §9.
4. **First quarterly DR drill scheduled Q4 2026** — until then, monthly subset drill + 2026-08-18 manual discovery are the evidence.
5. **No formal DPDP compliance review** below the significant data fiduciary threshold. Tracked in §9.
6. **Single-operator model** — no formal on-call rotation. Per 02-access-control §6a Edge 6 + 07-incident-management §3.8.
7. **All other exceptions** follow 01-info-security §6.

6a. Edge Cases & Decision Matrix

Specific scenarios that test the policy's boundaries. Each entry includes the trigger, the decision, and the rationale.

Edge case 1 — Prod DB is corrupted mid-shift (single-container data wipe)

- **Trigger.** erp-prod-db-1 is up but data corruption is detected (e.g., wrong query results, schema integrity violation). Named volumes intact.
- **Decision matrix.**

Step	Allowed?	Why
Restore from latest backup to a scratch MariaDB	YES	../04-runbooks/04.3 §“Single container”; RTO 30 min
Diff against prod counts (acceptable drift $\pm 5\%$)	YES	Catches data loss window
Promote restored DB to prod	ONLY with Venkat approval	§3.3.1 — promotion is deliberate
Skip the dry-run + diff	NO	Without diff, you don't know the RPO impact

- **Default action.** Dry-run on dev/QA first. Document the diff. Promotion is a deliberate act, not a side-effect of “we restored and it worked”. RTO target 30 min per §3.2.

Edge case 2 — Main VPS is destroyed (host down)

- **Trigger.** VPS provider failure, accidental wipe, hardware failure. Offsite backup intact.
- **Decision matrix.**

Step	Allowed?	Why
Provision a new VPS (5-10 min)	YES	DigitalOcean / Linode / Hetzner

Step	Allowed?	Why
Install Docker + base tools	YES	per ../04-runbooks/04.3 §“Step 2”
Clone repos from GitHub	YES	git clone git@github.com:venkat-narasimha/erpclaw.git + haritha-hospitals
Restore from offsite backup	YES	per ../04-runbooks/04.3 §“Step 5-12”
Skip offsite and use git history	NO	Git doesn't have DB dumps

- **Default action.** New VPS, restore from offsite. RTO target 1h per §3.2.

Edge case 3 — Both VPSes are down (region-wide outage)

- **Trigger.** Natural disaster / major internet outage / hosting provider bankruptcy affecting both main VPS and offsite VPS.
- **Decision matrix.**

Step	Allowed?	Why
Provision a new VPS in a different region	YES	Per ../04-runbooks/04.3 §“Total loss”
Restore from cold storage (Backblaze B2)	YES (future)	Today's gap: no cold storage exists
Restore from git history only	PARTIAL	Git has code + customizations, not DB
Use a 3rd-party ERPNext cloud as emergency	CONDITIONAL	Per frappe.cloud or similar; data migration is its own project

- **Default action.** Provision new VPS + restore from cold storage (future). Today's effective recovery is from git + any local backup that survived. RPO is potentially unbounded if no offsite copy survived.

Edge case 4 — Offsite VPS (venkat@135.125.196.35) is unreachable

- **Trigger.** Offsite VPS down for > 24h. We lose the offsite 1-of-3 in the 3-2-1 rule.
- **Decision matrix.**

Hours down	Action
0-4	Monitor; verify it's not local network
4-24	SEV-3 alert Venkat. Defer non-critical offsite rsyncs. Continue local backups.
24-72	SEV-2. Document in 09-compliance/exceptions/. Consider adding a second offsite (B2).
> 72	SEV-2 with policy temporarily violated. Annual review asks “do we need a second offsite?”.

- **Default action.** Per 01-info-security §6a Edge 5. Never silently let backups accumulate only locally.

Edge case 5 — GitHub is down (or repo deleted)

- **Trigger.** GitHub returns 5xx on `git clone`. Repo appears deleted in the web UI.
- **Decision matrix.**

Action	Why
Clone from a local mirror	YES — every VPS has a local clone
Push to an alternate remote (Bitbucket / GitLab) within hours	YES — DNS + SSH still work
Wait for GitHub to recover (typical outage < 1h)	YES (if not urgent)
Treat as SEV-1 if repo deleted	YES — repo deletion is catastrophic; recovery from local clone only

- **Default action.** Local clone is the immediate recovery. Push to alternate remote within 24h. GitHub repo deletion is rare; treat as SEV-1.

Edge case 6 — DuckDNS is down during a DR event

- **Trigger.** Mid-DR, the new VPS is up, the restored env is serving, but DuckDNS hasn't propagated the new IP yet. Users can't reach `pberpPROD.duckdns.org`.
- **Decision matrix.**

Action	Why
Manually call the duckdns API to update the IP	YES (per 06-communications-security §6a Edge 8)
Wait for the cron updater	RISKY — cron may also be down
Switch to a static IP + hosts file (per user)	NO — doesn't help real users
Use a different DNS provider as fallback	YES (future) — track in §9

- **Default action.** Manual duckdns API call. Verify with `dig`. If duckdns service is the failure, restart the duckdns-updater container.

Edge case 7 — A DR drill reveals a gap (e.g., missing fixture, broken custom app install)

- **Trigger.** Quarterly full DR drill: scratch env restored, DB restored, but `bench install-app haritha_hospital` fails.
- **Decision matrix.**

Action	Why
Document the gap in the drill report	YES
Add a LEARNINGS.md entry	YES
Update ../04-runbooks/04.3 with the fix	YES
Schedule a re-drill within 30 days	YES — verify the fix actually works
Treat as a real DR	NO — drill is a learning opportunity, not a real incident

- **Default action.** Document, fix, re-drill. Same as ../04-runbooks/04.3 §“Test cadence”.

Edge case 8 — Payroll week + DR event coincide

- **Trigger.** It's the 1st of the month (payroll day). Main VPS is down.
- **Decision matrix.**

Action	Why
Treat as Tier 1 — escalate immediately	YES — payroll slip delays are user-visible + legal risk
Pause payroll cron on the old VPS	YES — to avoid half-state data
Restore to new VPS first, then run payroll on the new VPS	YES
Skip payroll this month	NO — never (unless explicit Venkat YES)

- **Default action.** Tier 1 escalation. Restore priority on payroll env. New VPS payroll run. All-clear only after payroll verified.

Edge case 9 — Total loss (cold storage doesn't exist today)

- **Trigger.** Both VPSes down, offsite unreachable, no cold storage. Only git remote + local clones survive.
- **Decision matrix.**

Action	Why
Provision new VPS	YES
Clone all repos from GitHub (assuming GitHub is up)	YES — recovers code + customizations + docs
Recreate the prod DB from scratch using fixtures + master-data migration	PARTIAL — master data needs to be re-entered or restored from the user's local copies
Treat as a major incident + tabletop lesson	YES

- **Default action.** Today, total loss = effectively unrecoverable for DB data. Git + customizations survive; live data does not. This is why §3.3.6 (cold storage) is a \$9 priority. **The 2026-08-10..18 silent-failure streak is the closest we've come to this scenario** — and it was caught only because of a manual restore drill. Without that drill, the silent streak could have continued until a real disaster revealed the gap.

7. Related Documents

- 01-info-security.md — Umbrella + emergency-access + exception flow.
- 02-access-control.md — RBAC for DR operations + emergency-access flow.
- 03-asset-management.md — What counts as a Tier 1 asset (drives RTO/RPO).
- 04-cryptography.md — Backup encryption at rest (future).
- 05-operations-security.md — Daily heartbeat + monthly subset drill (sibling policy).
- 06-communications-security.md — Network / TLS posture during DR (sibling policy).
- 07-incident-management.md — SEV ladder + escalation when DR is needed (sibling policy).
- ../04-runbooks/04.3-disaster-recovery.md — Full restore procedure + DR drill template.
- ../04-runbooks/04.2-daily-ops.md — Daily heartbeat + monthly subset drill.
- ../04-runbooks/04.4-incident-response.md — SEV ladder + triage flow that escalates to DR.
- ../05-process/05.2-post-mortem.md — Post-mortem template for DR events.

- ../../../../learnings/LEARNINGS.md — Lessons #46, #48, #72, #74, #77, #78, #79, #80, #87, #88, #89, #90, #91, #93, #113, #114, #151, #153, #154, #157.
- ../../../../MEMORY.md — Tech stack, container names, backup cron schedule, offsite paths, git remotes.

8. Revision History

Version	Date	Author	Changes
1.0	2026-08-29	venkat-narasimha	Initial

9. Implementation Checklist

Concrete actions derived from this policy. Owner initials: VN = Venkat Narasimha; PA = Processbricks admin. Status as of 2026-08-29.

Immediate (this week)

- ☐ **Schedule the first quarterly full DR drill** for Q4 2026 (target: 2026-11-15). Owner: VN. Target: 2026-09-05. Status: Not Started.
- ☐ **Document the hospital IT lead contact** for external DR communication (Venkat routes via Telegram; identify a second contact). Owner: VN. Target: 2026-09-05. Status: Not Started.
- ☐ **Verify the 2026-08-18 manual restore drill findings** are reflected in ../04-runbooks/04.3-disaster-recovery.md. Owner: PA. Target: 2026-09-05. Status: Not Started.

Short-term (2026-Q3)

- ☐ **Implement Backblaze B2 cold storage** (weekly export, encrypted with age). Owner: VN. Target: 2026-10-31. Status: Not Started.
- ☐ **Author the DR drill report template** (per ../04-runbooks/04.3 §“Test cadence” pass criteria). Owner: PA. Target: 2026-09-30. Status: Not Started.
- ☐ **Implement encrypted backups at rest** with age (cross-link 04-cryptography §3.6). Owner: VN. Target: 2026-12-15. Status: Not Started.
- ☐ **Add a second offsite (B2 or equivalent)** so the 3-2-1 invariant survives a single offsite failure. Owner: VN. Target: 2026-10-31. Status: Not Started.
- ☐ **Author an emergency-credential-access playbook** (cross-link 02-access-control §6). Owner: VN. Target: 2026-10-31. Status: Not Started.

Medium-term (2026-Q4)

- ☐ **Run the first quarterly full DR drill** to a scratch env (target: 2026-11-15). Owner: VN. Target: 2026-11-15. Status: Not Started.
- ☐ **Cyber-insurance review** (annual cycle). Owner: VN. Target: 2026-12-15. Status: Not Started.
- ☐ **DPDP Act 2023 review** (annual). Owner: VN. Target: 2026-12-15. Status: Not Started.
- ☐ **Alternate Git remote** (Bitbucket / GitLab / self-hosted Gitea) as DR fallback for GitHub. Owner: VN. Target: 2026-11-30. Status: Not Started.
- ☐ **Annual tabletop exercise** (paper walk-through of total-loss scenario). Owner: VN. Target: 2026-12-15. Status: Not Started.

Long-term (2027+)

- **Hot standby / active-passive cluster** (replaces backup-based restore as primary). Cost: high (always-on second VM). Owner: VN. Target: TBD. Status: Not Started.
- **Cloud-based ERPNext (Frappe Cloud or equivalent) as DR fallback.** Owner: VN. Target: TBD. Status: Not Started.
- **DPIA + DPIA-style review** for any new vendor storing PHI. Owner: VN. Target: TBD. Status: Not Started.

Recurring verification (runs forever)

- **Daily heartbeat** — local + offsite backup freshness (per 05-operations-security §3.3). Owner: PA. Frequency: daily. Status: Done.
- **Daily SHA-256 cross-check** (local vs offsite). Owner: PA. Frequency: daily. Status: Done.
- **Weekly cron + script + key audit** (LEARNINGS #74 6-check). Owner: PA. Frequency: weekly. Status: Done.
- **Monthly restore subset drill** (gzip parse + CREATE TABLE count). Owner: PA. Frequency: monthly. Status: Done.
- **Quarterly full DR drill** (scratch env restore + login + sample records). Owner: VN. Frequency: quarterly. Status: Not Started (first cycle Q4 2026).
- **Annual tabletop** (paper walk-through). Owner: VN. Frequency: annually. Status: Not Started.
- **Annual RTO/RPO actual-vs-target review.** Owner: VN. Frequency: annually. Status: Not Started.
- **Annual vendor-dependency review** (DuckDNS, Let's Encrypt, GitHub, offsite VPS, VPS provider). Owner: VN. Frequency: annually. Status: Done.
- **Annual policy review** (re-read, increment version). Owner: VN. Frequency: annually. Status: Done (this revision).

Backup tested quarterly beats backup never tested. Document the offsite path or lose the offsite path. The 2026-08-10..18 streak is the proof.